

SWD80PS – Secure Software and Web Development**Final Practical Assessment**

Semester 1, 2026

NQF Level 8

12 Credits

Student Name:**Student ID:****Lecturer:**

Mr. Mbaunguraije Tjikuzu

Due Date:

----/----/2026

1. Assessment Brief

Objective

This practical assessment evaluates your ability to identify and remediate common security vulnerabilities in a web application. You will be given a deliberately vulnerable Flask web application and must apply secure coding principles to fix all 12 vulnerabilities.

Scope

The assessment covers the following topics from Units 1–5 of the course:

- **Secure Coding Practices:** Input validation, output encoding, error handling
- **Authentication & Access Control:** Password handling, session management, role-based access
- **Cross-Site Scripting (XSS):** Reflected and stored XSS prevention
- **CSRF Prevention:** Token-based cross-site request forgery protection
- **SQL Injection & Database Security:** Parameterized queries, secure data storage
- **Security Headers:** CSP, X-Frame-Options, X-Content-Type-Options
- **File Upload Security:** Type validation and size limits
- **Rate Limiting:** Login attempt throttling

Platform

You will use **GitHub Codespaces** – a browser-based development environment. No software installation is required. You will receive access to a private GitHub repository containing the vulnerable application.

2. Instructions

Follow these steps in order:

Step 1: Create or Confirm Your GitHub Account If you do not already have a GitHub account, create one at <https://github.com/signup>. Use your personal email address. A step-by-step guide is available at:
https://github.com/mtjikuzu/swd80ps-practical/blob/main/github_account_guide.md

Step 2: Send Your GitHub Username Send your GitHub username to your lecturer or to the **class representative** so you can be added to your private repository.

Step 3: Accept the Repository Invitation You will receive an email invitation from GitHub. Click **View Invitation** then **Accept Invitation** to access your private repository.

Step 4: Open in Codespaces (Browser-Based Coding) Codespaces gives you a full VS Code editor in your web browser — no software installation needed.

Follow these steps once you have accepted the repository invitation:

1. Go to your private repository URL (provided by your lecturer).
<https://github.com/mtjikuzu/swd80ps-practical-student-XX>
2. Look for the green **Code** button near the top-right of the repository page. Click it.
3. A dropdown menu will appear. Select the **Codespaces** tab.
4. Click the **Create codespace on main** button.
5. Wait 1–2 minutes while GitHub builds your environment. You will see a loading screen.
6. A browser-based VS Code editor will open automatically with:
 - A file explorer on the left (showing all project files)
 - A terminal panel at the bottom (for running commands)
 - Python and Flask already pre-installed

Tip: Codespaces saves your work automatically. You can close the browser tab and return later — your code will still be there. Each GitHub account gets 60 free hours per month.

Step 5: Configure Your Student ID

1. In the file explorer, open `challenge.config.py`
2. Set `STUDENT_ID = X` where X is the unique ID your lecturer provided
3. Save the file (Ctrl+S)

Step 6: Explore the Application In the terminal (bottom panel), run:

```
pip install flask && python app.py
```

Open the app at <http://127.0.0.1:5000> and explore all routes: /feedback, /search, /login, /profile, /upload, /admin.

Step 7: Identify and Fix All 12 Vulnerabilities Edit `app.py` to fix each vulnerability. The source code has comments marking each vulnerable area with `# VULN N:.` Fix them all.

Step 8: Run the Test Suite

```
python tests/test_fixes.py
```

All 12 tests must show **[PASS]**. If any show **[FAIL]**, review and fix that vulnerability.

Step 9: Commit and Push Your Changes

```
git add -A
git commit -m "Fixed all 12 vulnerabilities"
git push
```

Step 10: Take a Screenshot Take a screenshot of the terminal showing 12/12 passed test results.

3. Marking Rubric (50 Marks)

Criterion	Evidence Expected	Marks
Vulnerability identification and remediation	All 12 vulnerabilities correctly identified and fixed. Code comments or commit messages reference each vulnerability.	30
Code quality and secure practices	Fixes follow secure coding best practices (parameterized queries, proper escaping, input validation, error handling). No bypasses or shortcuts.	10
Testing evidence	Screenshot of test suite output showing 12/12 passed.	5
Documentation and commits	Meaningful commit messages, clear code comments, professional presentation.	5
Total		50

Pass requirement: Minimum 24/50 (48%).

4. Submission Requirements

You do not need to zip or upload your code. Your lecturer already has access to your private repository.

Submit the following via the Moodle assignment dropbox:

1. **Repository URL:** The full URL to your private GitHub repository (e.g., <https://github.com/mtj>).
2. **Screenshot:** A clear screenshot showing the output of `python tests/test_fixes.py` with all 12 tests passing
3. **(Optional) Video Walkthrough:** A 2–3 minute video recorded on your phone explaining three of your fixes. Upload to Google Drive and share the link.

5. Deadline and Late Submission Policy

Assessment Opens: Immediately upon receiving access

Assessment Closes: 20/06/2026 at 14:00 (2 PM)

Submission via: Moodle assignment dropbox

Late Submission Policy:

- Submissions received after the deadline will be subject to a penalty of 10% per day (including weekends).
- Submissions more than 5 days late will receive a mark of zero.
- Extensions must be requested in writing at least 48 hours before the deadline.

6. Academic Integrity Statement

This is an **individual assessment**. By submitting this work, you declare that:

1. All work submitted is your own original work.
2. You have not copied code or solutions from other students.
3. You have not shared your `challenge.config.py` file or `STUDENT_ID` with anyone.
4. You have not used generative AI to produce the complete solution without understanding the code.
5. You understand that plagiarism detection tools will be used and that academic dishonesty will result in disciplinary action in accordance with IUM's Academic Integrity Policy.



International University of Management
Faculty of Information & Communication Technologies

Student Signature:

Date:

Student Number:
